

> Anna-Mariya Mateyna | 29 August 2025

BOSIDES
FRANKFURT

Hunter vs. Hunted

A Ransomware Showdown with Hunters International



Anna-Mariya Mateyna



BSIDES
FRANKFURT



#bsidesFRA25





Agenda



- Threat Actor Profile
- The Hunt: Reconstructing the Attack Chain
 - ◆ Course of Events
 - ◆ Attack Chain Analysis (TTPs)
- The Aftermath
 - ◆ Critical Fixes and Lessons Learned
- Q & A





Hunters International

Ransomware-as-a-Service (RaaS)

- **Tech:** Written in Rust, double extortion model (encrypt & exfiltrate)
- **Motivation:** Financial
- **Targets:** Healthcare, Manufacturing, Education, Government, Automotive, Logistics
- **Tactics:** Credential theft, lateral movement, data exfiltration, backup deletion



Hunters International Timeline



Late
2023



Emergence of “Hunters International”
(likely Hive code reuse -> approx. 60% code similarity).
Officially denied being a rebrand of Hive.

2023-
2024



Global attacks (~30 countries).

2024



Notable victims: ICBC London, Tata Technologies,
Fred Hutchinson Cancer Center, U.S. Marshals Service

July
2025



Shutdown officially announced
& free decryptors released.

July
2025



Emergence of “World Leaks”
(focus on data theft & extortion).



Project Closure & Free Decryptors

News

6h 29m

Project Closure and Free Decryption Software for Affected Companies

We, at Hunters International, wish to inform you of a significant decision regarding our operations. After careful consideration and in light of recent developments, we have decided to close the Hunters International project. This decision was not made lightly, and we recognize the impact it has on the organizations we have interacted with.

As a gesture of goodwill and to assist those affected by our previous activities, we are offering free decryption software to all companies that have been impacted by our ransomware. Our goal is to ensure that you can recover your encrypted data without the burden of paying ransoms.

We understand the challenges that ransomware attacks pose, and we hope that this initiative will help you regain access to your critical information swiftly and efficiently. To access the decryption tools and receive guidance on the recovery process, please visit our official website.

We appreciate your understanding and cooperation during this transition. Our commitment to supporting affected organizations remains our priority as we conclude our operations.

Share on:   



World Leaks



Companies

News

Sign Up

Companies

All ⁶⁶ Awaiting ⁴ Disclosed ⁴ Published ⁶²

Q Filter

Motor Controls Inc. United States of America	1d 02h 01m	
Revenue \$133M	Employees —	Views 208
Springs Christian Academy Canada	1d 02h 02m	
Revenue \$5M	Employees 31	Views 253
Sika Footwear Denmark	1d 02h 01m	
Revenue \$9.4M	Employees —	Views 232
Sneg Proprete France	1d 02h 01m	
Revenue \$49.3M	Employees 897	Views 310

Overview Storage

Description

Founded in 1980 as a privately held corporation, Motor Controls Inc has firmly established itself as an industry provider in the design, development, and manufacturer of custom high quality proprietary custom control panel solutions for the most respected OEM in the United States and around the world.

Revenue	Employees	Stocks	Country
\$133M	—	—	United States of America

Website
motorcontrols.com

Status: **Disclosed** Updated: **21h 58m**



The Hunt: Reconstructing the Attack Chain

BOSIDES
FRANKFURT



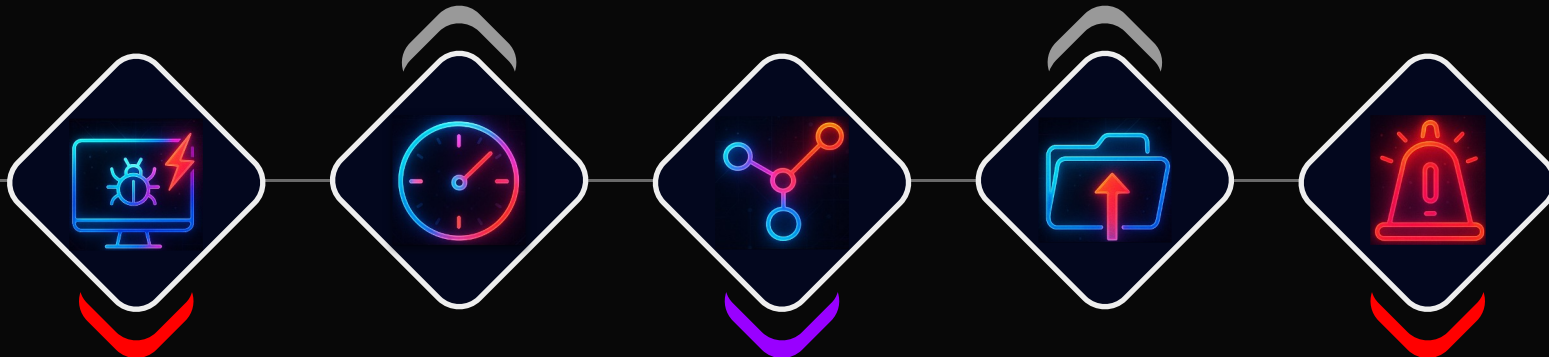
Course of Events

Dormancy & Low-Level Activity

- **Creds:** Dumps LSASS creds slowly to evade AV.
- **Persistence:** Hides backdoors via ADS/system tweaks.
- **Warning:** EDR/XDR alerts ignored, attacker continues.

Mass Data Exfiltration & Staging

- **Data Theft:** Targets critical file server.
- **Exfiltration:** Steals 100s of GB via SMB/FTP.
- **Tools:** Uses rclone/other transfer utilities.



Initial Compromise & Foothold

- **Access:** Stolen creds & exposed service, harvest more accounts.
- **Persistence:** RMM tool installed.
- **Recon:** Scans network for targets.

Escalation & Lateral Movement

- **Breakthrough:** Uses stolen creds to gain admin on core network/Domain Controller.
- **Actions:** Enumerates AD & scans all devices.
- **Alarm:** EDR flags mass lateral movement.

Impact & Detection

- **Ultimate Privilege:** Domain Admin, full control.
- **Critical Targets:** Maps VMware, NAS, backups.
- **Detection:** New C2 triggers major EDR alert.
- **Impact:** Corrupts VMs, deletes backups.
- **Extortion:** Publishes ransom threat on leak site.





The Unlocked Door: How They Got In



Tool / Command Used	Observed TTP
Stolen Local Credentials	T1078.003: Valid Accounts: Local Accounts
RDP Client (from external IP)	TA0001 - Initial Access (T1078 - Valid Accounts)

- **Initial Vector:** RDP access to the company's regional network.
- **The Flaw:** A FortiGate VPN exposed to the internet without MFA.
- **The Target:** A server - a system with no EDR agent and an unsupported OS.
- **The Evidence:**
 - ◆ Event ID 21, 4624, 4625 | Successful Logon - a successful logon and logoffs on the target server



Going Dark: Persistence & Credential Theft

Tool / Command Used	Observed TTP
AnyDesk.exe	T1219: Remote Access Software
cmd.exe (for ADS)	T1564.001: Hide Artifacts: Hidden Files and Directories
Windows Service Control (sc.exe)	T1543.003: Create or Modify System Process: Windows Service
Mimikatz.exe	T1003.001: OS Credential Dumping: LSASS Memory
rundll32.exe / comsvcs.dll	T1218.011: System Binary Proxy Execution: Rundll32

- **Legitimate RAT:** AnyDesk.exe installed in C:\Users\[...]\Downloads\.
- **Stealth Service:** Created service "sss" to execute from an Alternate Data Stream (C:\windows\cmd.exe:ss). This hides the malicious binary from standard file system views.
- **Mimikatz:** Executed from C:\Users\[...]\Downloads\mimikatz-master\x64\.
- **LSASS Dump:** Used a living-off-the-land binary (comsvcs.dll) to dump LSASS memory without dropping a known hacking tool on disk.
 - ◆ rundll32.exe C:\windows\System32\comsvcs.dll, #24 ... \Windows\Temp\3INxN.lnk full



The Jump: From a Regional Compromise to a Full-Blown Corporate Breach

Tool / Command Used	Observed TTP
Remote Desktop Client	T1021.001: Remote Services: Remote Desktop Protocol
Stolen Domain Credentials	T1078.002: Valid Accounts: Domain Accounts

- **Timestamp:** 3 months after infiltration
- **The Pivot Point:** The invasion escalated. All attacks on the central infrastructure originated from one single NAT IP - the NAT IP for the branch office network, used as a proxy to mask the TA's true origin and make their traffic appear internal.
- **The Stolen Key:** Using credentials harvested from the regional network, they achieved their first core admin access.
- **The Evidence:**
 - ◆ Event ID 4624 | Successful Logon - a successful logon, on a critical server



Mapping the Kingdom: What's Valuable Here?

Tool / Command Used	Observed TTP
Advanced IP Scanner	T1046: Network Service Discovery
Powershell.exe (Get-ADUser, etc.)	T1087.002: Account Discovery: Domain Account
net.exe	T1018: Remote System Discovery
Google Chrome	T1082: System Information Discovery (for vSphere/Backup)
WinSCP, PuTTY	TA0008 - Lateral Movement (T1021.006) & TA0011 - C2

- **Objective:** Identify high-value data and critical infrastructure.
- **AD Enumeration:** Ran extensive PowerShell commands to map the domain.
 - ◆ Get-ADComputer -Filter * | Export-Csv AllWindows.csv
 - ◆ net group "domain admins" /domain
- **Infrastructure Discovery:** Used Chrome Incognito to browse vSphere, NAS devices, and Veeam interfaces.

The Great Exfiltration: Stealing the Crown Jewels

Tool / Command Used	Observed TTP
rclone.exe	T1048: Exfiltration Over Alternative Protocol
Windows SMB Client	T1039: Data from Network Shared Drive
(Implied Staging)	T1074.001: Data Staged: Local System
(Implied Exfiltration)	T1041: Exfiltration Over C2 Channel

- **Main Target:** The file server.
- **The Dead End:** Their initial attempts to use rclone to SFTP data out from two of the attacked servers failed. Why? Our analysis showed those servers had no direct internet access. A small win for security policy!
- **The Successful Method:** They pivoted. Data was pulled via SMB from the file server to their compromised host, which did have a path out.
- **The Scale:** ~300 GB of data exfiltrated over 5 days.



Scorched Earth & The Mistake

Tool / Command Used	Observed TTP
module.dll (RMM Tool)	T1219: Remote Access Software
rundll32.exe	T1218.011: System Binary Proxy Execution: Rundll32
(Implied C2 Traffic)	T1071.001: Application Layer Protocol: Web Protocols
Veeam B&R Console, vSphere Client	TA0040 - Impact (T1485 - Data Destruction, T1561 - Disk Wipe)

- **Objective:** Cause maximum damage and establish a final C2 channel.
- **Destruction:** Logged into Veeam and vSphere with the admin account and began deleting jobs and disabling systems. We found evidence in window titles like "Confirm Job Delete".
- **The Mistake:** On one of the servers they tried to set up a new backdoor.
 - ◆ **The Tool:** s.dll, a component of NinjaRMM.
 - ◆ **The Command:** rundll32.exe s.dll, GetApexMPI
 - ◆ **The C2 Beacon:** An outbound connection to a TA's external machine.
- **The "Gotcha" Moment:** This activity was too anomalous to ignore and triggered the high-fidelity Cortex XDR alerts that finally exposed them.





BOSIDES
FRANKFURT

The Aftermath



Lessons from the Hunt

- **Key Tools:** Mimikatz, AnyDesk, Advanced IP Scanner, rclone, procdump64, PsExec.
- **The Obvious:** MFA Everywhere. The single most critical defense that would have prevented this entire chain of events.
- **The Tactical:**
 - ◆ **Network Segmentation:** Isolate regional networks from the core. A fire in the garage shouldn't burn down the house.
 - ◆ **Endpoint Visibility:** No more blind spots. Every server, every workstation needs an EDR agent.
 - ◆ **Privileged Access:** Lock down admin accounts. Use jump servers and LAPS.
- **The Process:** An alert must be treated as a fire alarm. A rigorous, accountable process for investigating and responding to every critical detection needs to be applied.





BO SIDES
FRANKFURT

Q & A

THANK
YOU!

